

Topologia con FortiGate

Asignatura: Seguridad de redes

Estudiante: Manuel Cruz

Docente: Jonathan Rondón

Fecha: 10 de julio de 2026

1. Objetivo de la Red

Implementar un firewall perimetral FortiGate que segmente una red corporativa simulada en dos zonas (usuarios y servidores), garantizando:

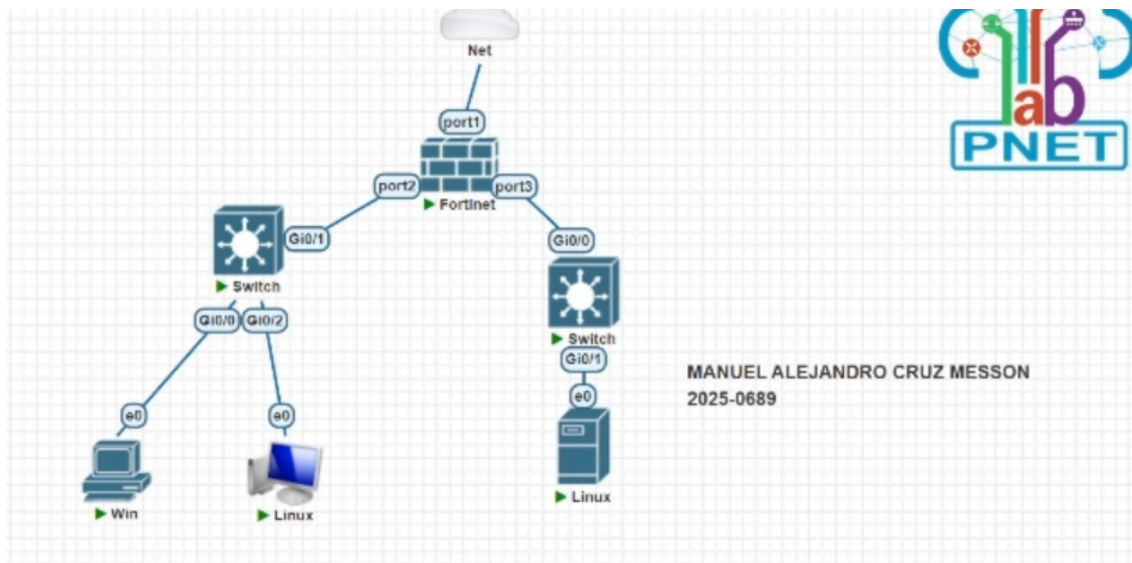
- Conectividad controlada a Internet para la LAN de usuarios, con inspección profunda del tráfico saliente.
- Publicación de un servidor web interno accesible únicamente por HTTP desde la LAN de usuarios, protegido con un Web Application Firewall (WAF).
- Restricción de acceso a redes sociales y al dominio institucional itla.edu.do.
- Bloqueo de llamadas de voz/video por WhatsApp, permitiendo el uso de mensajería de texto.
- Detección y bloqueo de escaneos de red (Nmap, escáneres de vulnerabilidades) mediante IPS y políticas Anti-DoS.
- Registro (logging) de todos los eventos de seguridad relevantes para su posterior auditoría.

2. Topología de Red

2.1 Direcccionamiento IP

Zona	Interfaz física	Rol	IP / Máscara	Rango útil	Gateway
WAN	port1	Salida a Internet	10.0.0.220/24	—	10.0.0.1
LAN Usuarios	port2	Red interna de usuarios	10.6.89.1/25 (255.255.255.128)	10.6.89.2 – 10.6.89.126	10.6.89.1
LAN Servidores	port3	Red interna de servidores	10.6.89.129/28 (255.255.255.240)	10.6.89.130 – 10.6.89.142	10.6.89.129

Servidor web publicado: 10.6.89.130



2.2 Diseño de subredes

No se utilizaron VLANs: al no solaparse los bloques 10.6.89.0/25 (usuarios) y 10.6.89.128/28 (servidores), la segmentación se resolvió con interfaces físicas dedicadas (port2 / port3), simplificando el diseño y facilitando la aplicación de políticas independientes por zona.

2.3 Evidencia — Interfaces configuradas

Physical Interface 3						
☐	LAN-Servidores (port3)	Physical Interface	10.6.89.129/255.255.255.240	PING HTTPS		
☐	Lan-usuarios (port2)	Physical Interface	10.6.89.1/255.255.255.128	PING HTTPS	2	10.6
☐	port1	Physical Interface	10.0.0.220/255.255.255.0	PING HTTPS SSH HTTP		

Panel Network > Interfaces mostrando las tres interfaces físicas activas: port1 (WAN, 10.0.0.220/24, con acceso PING/HTTPS/SSH/HTTP), Lan-usuarios (port2) (10.6.89.1/25, PING/HTTPS) y LAN-Servidores (port3) (10.6.89.129/28, PING/HTTPS).

3. Enrutamiento

Se configuraron dos rutas: la ruta por defecto hacia Internet a través de port1, y una ruta explícita hacia la subred de servidores a través de port3.

☐	0.0.0.0/0	10.0.0.1	port1	Enabled
☐	10.6.89.128/28	0.0.0.0	LAN-Servidores (port3)	Enabled

Network > Static Routes: 0.0.0.0/0 con gateway 10.0.0.1 vía port1, y 10.6.89.128/28 vía la interfaz LAN-Servidores (port3).

4. Asignación Dinámica de Direcciones (DHCP)

La LAN de usuarios recibe direccionamiento automático mediante un servidor DHCP configurado directamente sobre la interfaz port2.

DHCP Server

DHCP status

↑ Enabled

↓ Disabled

Address range

10.6.89.2-10.6.89.126

+

Netmask

255.255.255.128

Default gateway

Same as Interface IP

Specify

DNS server

Same as System DNS

Same as Interface IP

Specify

Lease time ⓘ

604800

second(s)

Network > Interfaces > port2 > DHCP Server: rango de direcciones 10.6.89.2 – 10.6.89.126, máscara 255.255.255.128, gateway por defecto igual a la IP de la interfaz, DNS heredado del sistema y tiempo de concesión (lease) de 604800 segundos (7 días).

5. Políticas de Firewall

Se definieron políticas independientes por flujo de tráfico, cada una con los perfiles de seguridad correspondientes a su función:

#	Nombre	Origen → Destino	Servicio	NAT	Perfiles de seguridad aplicados
1	USR-a-S RV-HTTP	LAN-Usua rios → LAN-Servi dores	HTTP	Deshabilitado	WAF (WAF-ServidorWeb), IPS
2	USR-a-W AN	LAN-Usua rios → port1 (Internet)	ALL	Habilitado	Control de Aplicaciones (AppCtrl-Bloqueos), DNS Filter (DNS-Bloqueo-ITLA), SSL Inspection

Lan-usuarios (port2) → LAN-Servidores (port3) 1											
☐	USR-a-SRV-HTTP (1)	LAN-Usuarios	all	always	HTTP	✓ ACCEPT	✖ Disabled	Standard	no-inspection WAF-ServidorWeb	✓ All	
Lan-usuarios (port2) → port1 1											
☐	USR-a-WAN (2)	LAN-Usuarios	all	always	ALL	✓ ACCEPT	✓ NAT	Standard	AppCtrl-Bloqueos DNS-Bloqueo-ITLA	✓ All	
Implicit 1											

Policy & Objects > Firewall Policy: la política USR-a-SRV-HTTP permite tráfico HTTP de usuarios hacia servidores sin NAT (comunicación interna) y aplica WAF; la política USR-a-WAN permite salida a Internet con NAT habilitado y aplica control de aplicaciones y filtrado DNS.

El **Implicit Deny** al final de la lista bloquea cualquier tráfico no contemplado explícitamente, incluyendo comunicación directa no autorizada entre port2 y port3 fuera de HTTP

6. Filtrado Web y DNS — Bloqueo de Redes Sociales e itla.edu.do

Para bloquear de forma efectiva tanto el acceso HTTP como HTTPS (donde el filtrado por URL es limitado por el cifrado), se implementó un **DNS Filter** con reglas estáticas de dominio.

The screenshot shows the configuration for a DNS filter named 'DNS-Bloqueo-ITLA'. It includes fields for Name and Comments, and toggle switches for 'Redirect botnet C&C requests to Block Portal' and 'Enforce 'Safe Search' on Google, Bing, YouTube'. Below these is a section for 'FortiGuard Category Based Filter' (disabled) and a 'Static Domain Filter' section. The 'Domain Filter' is enabled, showing a table with two entries: '*.itla.edu.do' (wildcard) and 'itla.edu.do' (simple), both with the action 'Redirect to Block Portal' and status 'Enable'.

Domain	Type	Action	Status
*.itla.edu.do	wildcard	✖ Redirect to Block Portal	✔ Enable
itla.edu.do	simple	✖ Redirect to Block Portal	✔ Enable

Security Profiles > DNS Filter > DNS-Bloqueo-ITLA: filtro de dominio estático activo con las entradas itla.edu.do (tipo simple) y *.itla.edu.do (tipo wildcard, para subdominios), ambas con acción “Redirect to Block Portal”.

6.1 Validación — Tráfico bloqueado

2026/07/10 13:49:04		10.6.89.3	Blocked	http://itla.edu.do/favicon.ico
2026/07/10 13:49:04		10.6.89.3	Blocked	http://itla.edu.do/

Registro de tráfico web mostrando las peticiones http://itla.edu.do/ y http://itla.edu.do/favicon.ico desde el host 10.6.89.3, ambas con estado Blocked, confirmando que la política de filtrado opera correctamente.

7. Control de Aplicaciones — Restricción de WhatsApp y Redes Sociales

El perfil de Control de Aplicaciones combina el bloqueo por categoría (Social Media, Proxy) con overrides específicos por aplicación para permitir mensajería de texto en WhatsApp mientras se bloquean las llamadas de voz/video.

Categories

Mixed

All Categories

Business (179 , 6)

Collaboration (293 , 6)

Game (124)

Mobile (3)

P2P (85)

Remote Access (91)

Storage/Backup (296 , 16)

Video/Audio (206 , 13)

Web Client (18)

Cloud/IT (31)

Email (87 , 12)

General Interest (241 , 9)

Network Service (332)

Proxy (106)

Social Media (150 , 31)

Update (48)

VoIP (31)

Unknown Applications

Network Protocol Enforcement

Application and Filter Overrides

+ Create New

Edit

Delete

Priority	Details	Type	Action
1	WhatsApp_VoIP.Call	Application	Block
2	HTTP.BROWSER_Firefox	Application	Allow
3	Whatsapp_Web Whatsapp WhatsApp.File_Transfer	Application	Block

Security Profiles > Application Control: las categorías Social Media y Proxy están bloqueadas globalmente. En la tabla de overrides se aplica, en orden de prioridad: (1) WhatsApp_VoIP.Call → Block, (2) HTTP.BROWSER_Firefox → Allow, (3) Whatsapp_Web, Whatsapp y WhatsApp.File_Transfer → Block.

7.1 Validación — Tráfico bloqueado

2026/07/10 13:49:38		10.6.89.3	96.45.46.46 (dns2.fortigua...)	Whatsapp	Block	
2026/07/10 13:49:33		10.6.89.3	96.45.45.45 (dns1.fortigua...)	Whatsapp	Block	
2026/07/10 13:48:54		10.6.89.3	57.144.162.34 (instagram....)	Instagram	Block	
2026/07/10 13:48:54		10.6.89.3	57.144.162.34 (instagram....)	Instagram	Block	
2026/07/10 13:48:04		10.6.89.3	57.144.174.1 (star-mini.c1...)	Facebook	Block	
2026/07/10 13:48:04		10.6.89.3	57.144.174.1 (star-mini.c1...)	Facebook	Block	

Registro de tráfico de aplicaciones desde 10.6.89.3 mostrando bloqueos efectivos sobre Whatsapp (dos eventos, resueltos vía servidores DNS de Fortiguard), Instagram y Facebook, todos con acción Block.

8. Prevención de Intrusiones (IPS) — Detección de Escaneo de Red

Se configuró un perfil IPS con firmas específicas orientadas a la detección de herramientas de reconocimiento y escaneo (Nmap, Acunetix, escáneres de servidores de aplicaciones), y se complementó con una política Anti-DoS que detecta anomalías de tráfico a nivel de capa 3/4.

IPS Signatures and Filters

[+ Create New](#) [Edit](#) [Delete](#)

Details	Exempt IPs	Action	Packet Logging
SEV SEV SEV OS Other +5		Block	Enabled
Acunetix.Web.Vulnerability.Scanner Acunetix.Web.Vulnerability.Scanner.Overlong.URL.Buffer Apache.Tomcat.Remote.Exploit.Account.Scanner Canvas.Ftpd.Scan +28	0	Block	Enabled
Apache.Struts.2.DefaultActionMapper.Redirection Apache.Struts.2.DefaultActionMapper.Remote.Command	0	Block	Enabled

Security Profiles > Intrusion Prevention > IPS-Base: firmas agrupadas por severidad con acción Block y Packet Logging habilitado; incluye firmas específicas como Acunetix.Web.Vulnerability.Scanner y Apache.Struts.2.DefaultActionMapper.Redirection.

Incoming Interface: port1

Source Address: all

Destination Address: all

Service: ALL

L3 Anomalies

Name	Logging	Action	Disable	Block	Monitor	Threshold
ip_src_session		Disable	Block	Monitor		5000
ip_dst_session		Disable	Block	Monitor		5000

L4 Anomalies

Name	Logging	Action	Disable	Block	Monitor	Threshold
tcp_syn_flood		Disable	Block	Monitor		2000
tcp_port_scan		Disable	Block	Monitor		1000
tcp_src_session		Disable	Block	Monitor		5000
tcp_dst_session		Disable	Block	Monitor		5000
udp_flood		Disable	Block	Monitor		2000
udp_scan		Disable	Block	Monitor		2000
udp_src_session		Disable	Block	Monitor		5000
udp_dst_session		Disable	Block	Monitor		5000

Policy & Objects > DoS Policy > DoS-AntiScan sobre port1: anomalías L3 (ip_src_session, ip_dst_session) y L4 (tcp_syn_flood, tcp_port_scan, tcp_src_session, tcp_dst_session, udp_flood, udp_scan, udp_src_session, udp_dst_session) con acción Block, logging activo y umbrales configurados (por ejemplo, tcp_port_scan con umbral de 1000).

8.1 Validación — Escaneo detectado

Date/Time	Level	Source	Action
2026/07/10 13:25:53	Warning	10.6.89.3	blocked
2026/07/10 13:18:44	Warning	10.6.89.3	blocked

Registro de eventos de seguridad con nivel Warning originados desde 10.6.89.3, con acción blocked, evidenciando la detección activa de actividad de escaneo por parte del IPS/Anti-DoS.

9. Web Application Firewall (WAF) — Protección del Servidor Web

El servidor web (10.6.89.130) está protegido mediante un perfil WAF aplicado en la política USR-a-SRV-HTTP, con firmas orientadas a los ataques web más comunes.

Signatures

 Edit	Search		
Status	Signature	Action	Severity
 Enable	Cross Site Scripting	 Block	
 Disable	Cross Site Scripting (Extended)	 Monitor	
 Enable	SQL Injection	 Block	
 Enable	SQL Injection (Extended)	 Block	
 Disable	Generic Attacks	 Block	
 Disable	Generic Attacks(Extended)	 Allow	
 Disable	Trojans	 Block	
 Disable	Information Disclosure	 Allow	
 Disable	Known Exploits	 Block	

Security Profiles > Web Application Firewall: firmas Cross Site Scripting y SQL Injection / SQL Injection (Extended) habilitadas con acción Block; Cross Site Scripting (Extended) en modo Monitor.

9.1 Validación — Ataques bloqueados

Date/Time	Severity	Source	Protocol	User	Action	Count	Attack Name
2026/07/10 13:52:12	High	10.6.89.3	6		dropped		HTTPURLSQLInjection
2026/07/10 13:51:31	High	10.6.89.3	6		dropped		AdobeXMLEntityInjection
2026/07/10 13:51:25	High	10.6.89.3	6		dropped		EasyHostingControlPanelFTPAccountSecurityBypass
2026/07/10 13:51:24	Medium	10.6.89.3	6		dropped		OxideWebServerDirectoryTraversal
2026/07/10 13:51:23	High	10.6.89.3	6		dropped		AdobeXMLEntityInjection
2026/07/10 13:51:16	Medium	10.6.89.3	6		dropped		OxideWebServerDirectoryTraversal
2026/07/10 13:51:13	Medium	10.6.89.3	6		dropped		VMware.Server.DirectoryTraversal
2026/07/10 13:51:13	Medium	10.6.89.3	6		dropped		Majordomo2.DirectoryTraversal

Registro de eventos de seguridad originados desde 10.6.89.3 (severidad High/Medium), todos con acción dropped, correspondientes a intentos de

explotación reales: HTTP.URI.SQL.Injection, Adobe.XML.Entity.Injection, Easy.Hosting.Control.Panel.FTP.Account.Security.Bypass, Oxide.WebServer.Directory.Traversal, VMware.Server.Directory.Traversal y Majordomo2.Directory.Traversal. Esta evidencia confirma que el WAF/IPS está deteniendo activamente ataques dirigidos al servidor web publicado.